Fiche 1 : l'injection SQL

Une injection SQL apparaît quand une application construit sa requête en collant directement ce que l'utilisateur a tapé. La saisie n'est alors plus une simple valeur : elle peut modifier la requête elle-même.

Par exemple, pour une recherche de produit par son nom :

```
SELECT * FROM produits WHERE nom = '<saisie>'
```

Si la saisie contient une apostrophe, celle-ci ferme la chaîne de caractères, et tout ce qui vient après est lu comme du SQL.

Ce qui peut aider

- `--` met en commentaire la fin de la requête, ce qui évite l'erreur due à l'apostrophe qui reste.
- `UNION SELECT` ajoute les résultats d'une deuxième requête à ceux de la première. Les deux doivent renvoyer le même nombre de colonnes.
- Avec SQLite, la liste des tables de la base se trouve dans la table `sqlite_master`, colonne `name`.

Comment s'en protéger

Utiliser des requêtes préparées : la saisie est envoyée à part, comme un paramètre, et la base ne la lit jamais comme du SQL.